
AI-Powered Email Threat Detection, Geolocation & Forensic Intelligence Platform

1. Background

1.1 Email as a communication channel

Email is one of the most commonly used communication methods in:

- Government organizations
- Colleges and universities
- Banks
- Hospitals
- Enterprises
- Financial institutions
- E-commerce companies

Example:

A college may use email to send students fee notices. A bank may send transaction alerts. A company may send invoices through email.

Because email is trusted and widely used, attackers also use it to target users.

1.2 Email as an attack vector

An **attack vector** means the method/path an attacker uses to attack a victim.

Email can be used for:

- Phishing
- Credential theft
- Malware delivery
- Financial fraud
- Business Email Compromise (BEC)
- Identity impersonation
- Fake invoice attacks
- Social engineering

Example:

```
From: accounts@paypal-security.com  
To: victim@gmail.com
```

```
Your account will be suspended.  
Verify your account immediately.  
[Verify Account]
```

The email looks like it comes from a trusted company, but the domain `paypal-security.com` may be malicious.

2. Major Email Threats

2.1 Phishing

Phishing is an attack where the attacker tricks a user into revealing sensitive information.

Common targets:

- Passwords
- OTPs
- Banking information
- Credit-card information
- Login credentials

Example

```
Subject: Your Microsoft Account Will Be Disabled
```

```
Your account has suspicious activity.
```

```
Click here to verify:  
https://micros0ft-login-example.com
```

The attacker tries to make the user believe the link belongs to Microsoft.

2.2 Email Impersonation

Impersonation means pretending to be another person or organization.

Example

From: ceo@company.com

Please purchase ₹2,00,000 worth of gift cards
and send me the codes immediately.

The attacker may actually control:

ceo-company@gmail.com

but uses the CEO's name:

Display Name: Rahul Sharma – CEO

This is called **display-name impersonation**.

2.3 Business Email Compromise — BEC

BEC is a targeted fraud attack where an attacker impersonates or compromises a business account.

Typical targets:

- CEO
- CFO
- Finance manager
- HR
- Procurement team

Example

From: CFO

Please transfer ₹15,00,000 to the following
new vendor account.
This is urgent.

The attacker wants the finance employee to transfer money.

2.4 Financial Fraud

Email can be used to manipulate victims into making unauthorized payments.

Example

Subject: Updated Bank Account Details

Our company's bank account has changed.

Please send today's payment to:

Account: XXXXXXXXX

IFSC: XXXXX

The attacker may have intercepted an existing business conversation.

2.5 Credential Theft

The attacker creates a fake login page.

Email

↓

Fake Microsoft Login

↓

Username + Password

↓

Attacker

The victim thinks they are logging into Microsoft, but the credentials are sent to the attacker.

3. Why Traditional Email Security Is Not Always Enough

Traditional systems commonly use:

- Spam filters

- Blacklists
- Static rules
- Signatures

These are useful but can struggle with sophisticated attacks.

3.1 Spam Filter

A spam filter identifies emails that appear unwanted or suspicious.

Example

If thousands of emails contain:

```
WIN MONEY NOW!!!
```

the filter can learn that similar messages are spam.

But attackers can change the wording:

```
Congratulations! Your reward is ready.
```

The new message may avoid a simple keyword rule.

3.2 Static Blacklist

A blacklist contains known malicious:

- Domains
- IP addresses
- URLs
- Email addresses

Example

```
Blacklist:
```

```
malicious-example.com
```

```
185.10.20.30  
bad-link.example
```

If an attacker uses a **new domain**, the blacklist may not contain it yet.

3.3 Signature-Based Detection

A signature represents a known pattern of malicious content.

Example

Known malware hash:

```
SHA-256:  
ABC123...
```

If the same malware appears again, it can be detected.

But a modified version may have a different hash.

4. Modern Techniques Used by Attackers

4.1 AI-generated language

Attackers can generate professionally written emails using AI.

Old phishing:

```
Dear sir,  
your account problem please verify.
```

Modern phishing:

```
Dear Customer,  
  
We detected an unusual authentication attempt  
associated with your account. Please verify your  
identity to prevent temporary account restrictions.
```

The second message looks much more professional.

4.2 Domain Lookalike

The attacker registers a domain visually similar to a legitimate domain.

Example

Real:

```
microsoft.com
```

Fake:

```
micros0ft.com
```

or

```
microsoft-security.com
```

The system should detect suspicious similarity.

4.3 Display Name Spoofing

The visible sender name may be trusted even when the actual address is different.

```
Display Name:  
Google Security Team
```

```
Actual email:  
security-alert@gmail.com
```

The system should analyze both.

4.4 Hidden Redirection

The displayed URL may look safe:

```
https://google.com
```

but clicking it may redirect to:

```
https://attacker-example.com/login
```

Therefore, MailTrace should analyze the actual URL and redirect chain where available.

4.5 Relay Chains

An email may pass through multiple mail servers.

Example:

```
Sender
↓
Mail Server A
↓
Mail Server B
↓
Mail Server C
↓
Recipient
```

The system analyzes the `Received:` headers to reconstruct this path.

5. Problem Statement — What Is Actually Missing?

The major problem is:

Existing email security systems often focus on **"Is this email malicious?"**, while investigators also need to understand **"How did this email travel, what infrastructure was involved, and what evidence can we reliably extract?"**

For example:

```
Email
↓
Detection
```

4.6 Advanced De-Obfuscation Pipeline

Attackers increasingly use visual and Unicode-based obfuscation to bypass simple text filters. MailTrace implements a multi-pass adversarial de-obfuscation pipeline before any NLP or ML analysis:

Pass 1 — Zero-Width Character Removal

Removes invisible Unicode characters (zero-width space, zero-width non-joiner, etc.) that can split keywords and defeat signature matching.

Pass 2 — Homoglyph / NFKC Normalization

Applies Unicode NFKC normalization to convert look-alike characters (e.g., Cyrillic 'а' → Latin 'a') into their canonical forms so that domain and body text can be compared reliably.

Pass 3 — Punycode Decoding

Decodes Internationalized Domain Names (IDN) from punycode (xn--) back to their Unicode representation so that visually deceptive domains are exposed.

Pass 4 — DOM / CSS Hidden-Text Inspection

When HTML parts are present, the pipeline inspects for text hidden via CSS techniques such as `display:none`, `font-size:0`, same foreground/background color, or off-screen positioning. Hidden payloads are extracted and fed into the detection engines.

Only after these four passes is the restored human-visible text passed to NLP, social-engineering detectors, and the ML classifiers. This ensures that obfuscated phishing language is analyzed in its true form.

4.7 Quishing (QR-Code Phishing) Detection

Quishing is a growing attack technique in which a malicious URL is embedded inside a QR code image attached to (or rendered inside) an email. Text-only scanners miss these payloads.

MailTrace therefore treats every image attachment (and embedded image) as a potential QR carrier:

- Images are decoded entirely in memory (no temporary disk writes of the raw payload).
- A QR-code decoder extracts any encoded content.
- Extracted strings that look like URLs are passed through the same URL-analysis and reputation pipeline used for ordinary hyperlinks.
- The resulting findings are attached to the case as image-based indicators (e.g., “QR payload → suspicious domain”).

This closes a common bypass path used by attackers who rely on the assumption that security tools only examine plain-text and HTML bodies.

↓

Phishing = YES

This is useful, but investigation requires:

Email

↓

Header analysis

↓

Authentication

↓

Relay path

↓

IP analysis

↓

Domain analysis

↓

Threat intelligence

↓

Campaign correlation

↓

Forensic report

6. Proposed Solution

Your proposed platform is:

AI-Powered Email Threat Detection, Geolocation and Forensic Intelligence Platform

The system combines:

NLP

+

Machine Learning

+

Email Forensics

+

IP Intelligence

+

Domain Intelligence

+

```
Threat Intelligence
+
Graph Analysis
+
Forensic Reporting
```

Its purpose is not simply to say:

```
"This email is dangerous."
```

It should provide a structured investigation:

```
Why suspicious?
  ↓
What indicators were found?
  ↓
How did the email travel?
  ↓
What infrastructure is involved?
  ↓
What authentication checks passed/failed?
  ↓
What related campaigns exist?
  ↓
How confident are these findings?
```

7. System Input

The platform can accept a raw email such as:

```
email.eml
```

An `.eml` file can contain:

- Sender
- Recipient
- Subject
- Body
- Headers
- Attachments

- MIME structure
- URLs

Example:

```
email.eml
|
+-- Headers
+-- Body
+-- URLs
+-- Attachments
+-- Authentication results
```

8. Fraudulent Email Detection Engine

This is the **AI detection layer**.

8.1 NLP

NLP = Natural Language Processing

NLP allows the system to analyze human language.

It can inspect:

- Subject
- Email body
- Urgency
- Threatening language
- Financial requests
- Credential requests
- Impersonation language

Example

```
URGENT!!!
```

```
Your account will be closed in 30 minutes.
```

Click here immediately.

NLP may identify:

Urgency = High
Threat language = High
Credential request = Possible

8.2 Social Engineering

Social engineering means manipulating a person rather than directly attacking a computer.

Common techniques:

Fear
Urgency
Authority
Curiosity
Reward
Trust

Example

I am your manager.
I am currently in a meeting.
Please transfer the payment immediately.

The attacker uses **authority + urgency**.

9. Suspicious Sender Detection

The platform can compare:

Display Name
+
Email Address

+

Domain

Example:

Display Name:
SBI Bank

Actual:
support@random-domain.com

This mismatch becomes an indicator.

10. Deceptive Domain Detection

The system can inspect:

- Domain spelling
- Character substitutions
- Subdomains
- Punycode
- Domain age
- DNS records
- MX records

Example

Original:
paypal.com

Suspicious:
paypa1.com

The character:

l

was replaced with:

This is a **lookalike domain**.

11. URL Analysis

The system can extract URLs from the email.

Example:

Email Body:

Click here:

<https://example.com/login>

It can analyze:

Domain

Path

Parameters

Redirects

HTTPS

Domain reputation

Suspicious characters

Example:

<https://secure-login.example.com/account/verify>

The system can check whether the domain is actually associated with the claimed organization.

12. Attachment Analysis

Email attachments may contain:

- PDF
- DOCX
- XLSX

- ZIP
- EXE
- Scripts

Example:

```
invoice.pdf.exe
```

The visible filename may try to deceive the user.

The platform can extract:

```
Filename
MIME type
Extension
Hash
Size
Metadata
```

For example:

```
SHA-256:
9f86d081...
```

The hash can be used to correlate the attachment with known threat intelligence.

13. AI/ML Classification

The system can classify an email.

Example:

```
Legitimate
Suspicious
Impersonated
Phishing
Fraud-related
```

Example output:

13A. Explainable Feature Vectors & pgvector Campaign Clustering

Beyond classical risk scores, MailTrace constructs a fixed-length **32-dimensional structural feature vector** for every analyzed email. The dimensions capture explainable signals such as:

- Authentication outcomes (SPF / DKIM / DMARC)
- Domain age and look-alike distance
- Presence of urgency / authority / financial language
- URL redirect depth and reputation
- Attachment type / hash novelty
- DOM cloaking indicators
- QR-payload presence
- Relay-path anomalies

Each vector is L2-normalized and stored in PostgreSQL using the **pgvector** extension. Campaign discovery is performed by cosine-distance nearest-neighbor search: emails whose vectors are close in this space are grouped into the same campaign even when domains or Message-IDs differ.

Because every dimension is human-interpretable, the system can explain similarity statements (example: “82 % of the similarity is driven by DOM cloaking + QR payload + identical ASN”). This keeps the clustering transparent for investigators and auditors.

13B. Model Training & Feedback Loop

The supervised classifiers (XGBoost / LightGBM / transformer heads) are trained on a combination of:

- Publicly available labeled phishing and BEC corpora
- Synthetic examples generated from known attack templates
- Organization-specific historical cases (where available and consented)

After deployment, analysts can label any case as “False Positive”, “Confirmed Fraud”, “Compromised Account”, etc. These labels are written back into a feedback dataset. Models are periodically retrained, versioned, and A/B-tested so that detection quality continuously improves without requiring a full system redeployment.

Classification: Phishing
Risk Score: 91/100
Confidence: 94%

Important distinction:

Risk score $\neq$ proof of criminal activity.

It is an analytical assessment based on available evidence.

14. Email Header & Protocol Analysis

This is one of the most important parts of your project.

Email headers contain technical information about the message.

Important headers include:

From
To
Return-Path
Reply-To
Received
Message-ID
DKIM
SPF
DMARC

15. From Header

Example:

From: ceo@company.com

This tells the displayed sender address.

But the `From` address alone should **not** be treated as proof of actual origin.

16. Return-Path

Example:

```
Return-Path: bounce@mailer.example.com
```

It can provide another identity associated with message delivery.

A mismatch may be relevant.

Example:

```
From:
ceo@company.com

Return-Path:
random-mailer@example.net
```

This deserves investigation.

17. Reply-To

Example:

```
From:
ceo@company.com

Reply-To:
attacker@gmail.com
```

If the victim replies, the response may go to the attacker.

This is a strong investigative indicator, although context matters.

18. Received Headers

`Received` headers help reconstruct mail-server hops.

Example:

```
Received:  
Server C
```

```
Received:  
Server B
```

```
Received:  
Server A
```

Conceptually:

```
Sender  
↓  
Server A  
↓  
Server B  
↓  
Server C  
↓  
Recipient
```

The platform can parse these headers and construct a relay graph.

19. Message-ID

Example:

```
Message-ID:  
<abc123@example.com>
```

It is an identifier associated with the email message.

It can help with:

- Correlation
- Investigation
- Duplicate detection
- Incident analysis

But Message-ID itself is not proof of the sender's identity because fields can be forged or manipulated.

20. SPF

SPF = Sender Policy Framework

SPF checks whether an IP address is authorized to send mail for a domain.

Example:

```
Domain:
company.com

Authorized sending servers:
1.2.3.4
5.6.7.8
```

If another server sends mail claiming to be from that domain:

```
9.9.9.9
```

SPF may fail.

Example result:

```
SPF = FAIL
```

21. DKIM

DKIM = DomainKeys Identified Mail

DKIM uses cryptographic signatures to help verify that a message is associated with a domain and that signed content was not modified after signing.

Conceptually:

```
Email
↓
Digital Signature
↓
Receiver verifies signature
```

Possible result:

```
DKIM = PASS
```

or

```
DKIM = FAIL
```

22. DMARC

DMARC = Domain-based Message Authentication, Reporting & Conformance

DMARC combines domain identity alignment with SPF/DKIM results and lets domain owners publish policies.

Example:

```
SPF  = PASS  
DKIM = PASS  
DMARC = PASS
```

Another example:

```
SPF  = FAIL  
DKIM = FAIL  
DMARC = FAIL
```

The platform can use these results as **evidence**, not as a single final verdict.

23. Origin Traceability

The system tries to identify the **earliest reliable sending infrastructure** visible in the available headers.

Example:

```
Recipient
  ↑
Mail Server C
  ↑
Mail Server B
  ↑
Mail Server A
  ↑
Earliest visible node
```

Important:

The earliest visible IP is not necessarily the attacker's real physical location.

Why?

Because attackers may use:

- VPN
- Proxy
- Tor
- Compromised servers
- Cloud infrastructure
- Botnets
- Open relays

Therefore your system should use terms like:

"probable origin"

rather than:

"attacker's exact location."

24. IP Geolocation

Once an IP address is extracted:

```
IP Address
  ↓
IP Intelligence
  ↓
```

```
Country
Region
City
ISP
ASN
Hosting Provider
```

Example:

```
IP:
203.0.113.10

Country:
India

Region:
Example Region

ASN:
AS12345
```

The system can display this on a map.

But geolocation should be presented as an **estimate associated with the IP**, not proof of a person's physical location.

25. ASN

ASN = Autonomous System Number

An ASN identifies a network operated by an organization.

Example:

```
IP
↓
ASN
↓
Network / ISP / Hosting Provider
```

This helps investigators understand what network owns or announces the IP range.

26. ISP

ISP = Internet Service Provider

Example:

```
IP:  
203.x.x.x  
  
ISP:  
Example Internet Provider
```

This provides network-level context.

It does **not automatically identify the individual user**.

27. VPN

A VPN can hide the original network from the recipient.

Example:

```
Attacker  
  ↓  
VPN  
  ↓  
Mail Server  
  ↓  
Victim
```

The investigator may see the VPN or hosting infrastructure instead of the attacker's actual connection.

28. TOR

Tor is an anonymity network.

Conceptually:

```
User
↓
Tor Node
↓
Tor Node
↓
Tor Exit
↓
Internet
```

Therefore identifying a visible IP does not necessarily identify the original person.

29. Domain Intelligence

The system can investigate the sender domain.

Useful information:

```
WHOIS / registration information
DNS
MX
NS
A / AAAA
TXT
Registrar
Nameservers
Hosting
Domain age
```

Example:

```
Domain:
fake-bank-example.com

DNS → IP
MX → Mail Server
NS → Nameserver
Registrar → Registrar information
```

This creates infrastructure intelligence.

30. WHOIS / Registration Intelligence

WHOIS-style registration information can provide information about a domain registration.

For example:

```
Domain:
example.com

Registrar:
Example Registrar

Created:
2026

Updated:
2026
```

Privacy protection may hide registrant details.

So your system should not promise:

"WHOIS reveals the attacker."

Instead:

"Domain registration intelligence provides additional infrastructure context."

31. DNS

DNS = Domain Name System

DNS translates names into network information.

Example:

```
mail.example.com
    ↓
IP address
```

Useful records include:

A
AAAA
MX
NS
TXT
CNAME

32. MX Record

MX = Mail Exchange

It identifies mail servers responsible for receiving email for a domain.

Example:

```
example.com
  ↓
MX
  ↓
mail.example.com
```

This helps understand email infrastructure.

33. Threat Intelligence

Threat Intelligence provides known information about:

- Malicious IPs
- Malicious domains
- URLs
- Malware hashes
- Previous campaigns
- Known indicators

Example:

```
Extracted IP:
198.51.100.20
```

Threat Intelligence:
Known suspicious infrastructure

The platform can increase investigative confidence when independent sources correlate.

34. Identity Correlation

The system can connect multiple indicators.

Example:

```
Email A
|
+--- Domain X
|
+--- IP Y
|
+--- URL Z

Email B
|
+--- Domain X
|
+--- IP Y
|
+--- URL Z
```

This suggests the two emails may share infrastructure.

35. Graph-Based Correlation

This is a powerful feature for your project.

Represent entities as nodes:

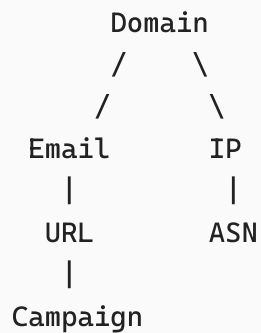
```
Email
Domain
IP
URL
```

Attachment
Sender
Campaign

Connections become edges:

Email —uses→ Domain
Domain —resolves→ IP
Email —contains→ URL
URL —hosts→ Domain
Email —belongs to→ Campaign

Example:



This allows investigators to see relationships instead of isolated indicators.

36. Campaign Correlation

Suppose you receive:

Email 1 → fake-bank.com
Email 2 → fake-bank.com
Email 3 → same IP
Email 4 → same URL pattern

The platform can group them:

Campaign #001

Emails: 4
Domains: 1
IPs: 1

URLs: 3
Common indicators: 5

This is more useful than analyzing each email separately.

37. Attribution Support

Your platform should use the phrase:

Attribution Support

rather than:

Automatic Attacker Identification

Because technical indicators usually cannot prove who physically sent an email.

Your system can say:

Possible Infrastructure:
Cloud-hosted server

Confidence:
82%

Evidence:

- Same IP
- Same domain cluster
- Same URL pattern
- Previous suspicious activity

But it should not automatically claim:

The attacker is Person X.

38. Compromised Account Detection

Sometimes the attacker does not create a fake domain.

Instead:

```
Legitimate Account
  ↓
Account Compromised
  ↓
Attacker logs in
  ↓
Fraudulent email sent
```

Example:

```
employee@company.com
```

may be a legitimate address, but the account could have been compromised.

This is an important distinction:

```
Spoofted account ≠ Compromised account
```

39. Alerting System

The platform should generate alerts based on risk and evidence.

Example:

```
🔔 HIGH RISK EMAIL
```

```
Risk Score: 91/100
```

```
Indicators:
```

- ✓ DMARC failure
- ✓ Lookalike domain
- ✓ Suspicious URL
- ✓ Urgency language
- ✓ Known suspicious IP

40. Fraud Score

You can create a normalized score:

0 ————— 100
Low High

Example:

0-29	Low
30-59	Medium
60-79	High
80-100	Critical

These ranges should be treated as your system's configurable risk policy, not a universal cybersecurity standard.

41. Dashboard

The analyst dashboard can contain:

```
+-----+
| EmailTrace AI |
+-----+
| Risk Score: 91/100 |
| Classification: Phishing |
+-----+
| Sender Analysis |
| SPF: FAIL |
| DKIM: FAIL |
| DMARC: FAIL |
+-----+
| Origin |
| IP: xxx.xxx.xxx.xxx |
| ASN: XXXXX |
| Country: Example |
+-----+
| Threat Intelligence |
| IP Reputation: Suspicious |
+-----+
```

42. Trace Map

You can visually show:

```
[Sender]
  |
  v
[Mail Server A]
  |
  v
[Mail Server B]
  |
  v
[Mail Server C]
  |
  v
[Recipient]
```

Each node can display:

```
IP
ASN
Country
ISP
Timestamp
Hostname
Confidence
```

43. Forensic Report

The system can generate a PDF containing:

Case Information

```
Case ID:
CT-2026-00421
```

Email Hash

```
SHA-256:
abc123...
```

43A. AI-Assisted Forensic Narrative (With Evidence Citations)

The forensic PDF report contains both structured tables (hashes, authentication results, IoCs) and a free-text narrative that helps a non-technical reader understand the case. This narrative is generated by an LLM under strict guardrails:

1. The LLM receives only a verified JSON object of findings. Each finding carries a stable identifier such as [F-001], [F-002], ...
2. The prompt instructs the model to cite the corresponding finding ID after every factual claim.
3. A post-generation regex validator discards any sentence that does not contain a valid finding citation. Hallucinated statements are therefore removed before the report is finalized.

Consequently the narrative remains readable while guaranteeing that every claim is traceable to an observable technical artifact. This design is essential for legal defensibility.

48A. Evidence Tiers (Epistemological Model)

To avoid overstating what technical analysis can prove, MailTrace classifies every piece of information into one of four explicit tiers:

Tier	Name	Meaning
1	Observed Evidence	Raw, directly extracted artifacts: headers, hashes, DNS answers, authentication results.
2	Infrastructure Association	Links derived from public or internal intelligence (e.g., IP → ASN, domain → registrar).
3	System Inference	Risk scores, campaign clusters, look-alike distances, ML classifications.
4	Human Legal Conclusion	Attribution of identity or intent. This tier is never produced automatically; it remains the investigator's responsibility.

The platform surfaces Tier-1 and Tier-2 data with high confidence, presents Tier-3 scores as analytical assessments, and never claims Tier-4 conclusions. This matches the language already used elsewhere in the document (“probable origin”, “risk score ≠ proof of criminal activity”).

Detection

Classification:
Phishing

Risk:
91/100

Authentication

SPF:
FAIL

DKIM:
FAIL

DMARC:
FAIL

Network Evidence

IP
ASN
ISP
Geolocation
Relay Path

Indicators

Suspicious URL
Lookalike Domain
Attachment Hash

44. Chain of Custody

This is extremely important for a forensic platform.

Chain of custody means maintaining a record of how digital evidence was:

Collected

↓

Stored

↓

Accessed

↓

Analyzed

↓

Reported

Example:

10:30 AM

Email uploaded

10:31 AM

SHA-256 generated

10:32 AM

Stored in evidence storage

10:40 AM

Analyst accessed evidence

11:00 AM

Report generated

This helps demonstrate that the evidence was handled systematically.

45. SHA-256 Evidence Hash

Suppose:

```
email.eml
```

is uploaded.

Your system calculates:

```
SHA-256:
```

```
A7F9.....
```

If the file changes:

Original hash:
A7F9...

Modified hash:
B82C...

The difference can reveal that the file contents changed.

46. Immutable Evidence Storage

For your architecture, you can use controlled evidence storage such as MinIO/object storage.

Concept:

```
Uploaded Email
  ↓
SHA-256
  ↓
Evidence ID
  ↓
Immutable/controlled storage
```

Example:

Case:
CT-2026-00421

Evidence:
EV-0001

Hash:
abc123...

47. Privacy Protection

Emails can contain sensitive information:

- Names
- Phone numbers
- Addresses
- Financial information
- Personal conversations
- Credentials

Therefore the system should support:

Data masking
Access control
Retention policy
Encryption
Audit logs
Role-based access

Example:

Instead of showing:

9876543210

to every user:

98*****10

could be displayed where appropriate.

48. Legal and Compliance Safeguards

The system should preserve evidence and access logs while respecting applicable privacy and evidence requirements.

For your project presentation, you can describe the system as:

A forensic assistance and intelligence platform, not an autonomous legal decision-making system.

This distinction is important.

48B. Legal Alignment — Section 63 BSA 2023 (Indian Law)

Under the Bharatiya Sakshya Adhiniyam, 2023 (Section 63), electronic records can be admitted as evidence when accompanied by a proper certificate and when the integrity of the record can be demonstrated. MailTrace is designed to assist human investigators in producing a complete digital-evidence bundle that supports this requirement:

- Original .eml file (or exact byte-for-byte copy) stored under an immutable object key
- Standalone SHA-256 hash file computed at the moment of ingestion
- Chain-of-custody log (who uploaded, who accessed, when analysis ran, when report was generated)
- Structured IoC export (CSV / JSON) containing all extracted indicators
- Technical certificate annexure that records the hash, timestamps, and system version

The software itself does not issue a legal certificate; it supplies the technical materials and audit trail that a qualified person can use to prepare the Section 63 certificate. This keeps the platform in the role of a forensic-assistance tool rather than an autonomous legal authority.

54A. Non-Blocking Pipeline & Access Control Note

The complete nine-module analysis pipeline (header parsing → de-obfuscation → NLP → URL/attachment inspection → authentication checks → IP/domain intelligence → graph correlation → risk scoring → report assembly) is designed to run asynchronously. Typical end-to-end latency for a single email is under two seconds on modest hardware.

Role-based access control (RBAC) governs only who may view cases, evidence fields, and generated reports. It never blocks or slows the analysis itself. Consequently an investigator can upload an email and almost immediately receive a full forensic package, while the organization retains fine-grained control over data exposure.

These sections complete the architectural picture already present in the Architecture Decision Records (ADR-002 through ADR-008) and bring the platform documentation into full alignment with the advanced capabilities of the system.

48C. Web Application Security Controls

In addition to email-forensics capabilities, the web interface and APIs of MailTrace must themselves be secured. The project implements the following controls:

Authentication & Sessions — Login for investigators and administrators uses strong password policies, secure session management or JWT tokens, and HTTPS-only cookies. Optional two-factor authentication can be enabled for high-risk roles.

CSRF & XSS Protection — CSRF tokens are required for all state-changing requests. React's default output escaping and Content-Security-Policy (CSP) headers are used to reduce cross-site scripting risk.

Input Validation & File Handling — Uploaded .eml files are subject to size limits and MIME-type checks. Headers and bodies are parsed safely; attachments are handled in controlled, non-executable contexts to prevent arbitrary code execution.

Rate Limiting & Logging — API endpoints enforce rate limits to mitigate brute-force and abuse attempts. Structured audit logs record login attempts, case access, evidence downloads, and report generation events.

Secrets Management — Database credentials, threat-intelligence API keys, and hashing salts are supplied via environment variables or a secrets vault. No secrets are hard-coded in source code or container images.

Secure Docker & Deployment — Containers run as non-root users on minimal base images. Network segmentation isolates frontend, backend, database, and evidence storage (MinIO). TLS is terminated for all external traffic.

These controls ensure that the forensic platform itself does not become an attack surface while investigators analyse high-value email evidence.

49. Expected Outcome 1 — Early Detection

The system should detect suspicious emails before users interact with them where the deployment architecture allows this.

Example:

```
Incoming Email
  ↓
EmailTrace AI
  ↓
Risk Analysis
  ↓
HIGH RISK
  ↓
Alert
```

50. Expected Outcome 2 — Improved Traceability

Instead of simply:

```
PHISHING
```

the analyst gets:

```
Phishing
  ↓
Suspicious Domain
  ↓
Suspicious URL
  ↓
Relay Path
  ↓
IP
  ↓
ASN
  ↓
Geolocation
  ↓
Threat Intelligence
```

51. Expected Outcome 3 — Investigation Support

Investigators can correlate:

```
Email
+
Domain
+
IP
+
URL
+
Attachment
+
Campaign
```

to understand the larger incident.

52. Expected Outcome 4 — Reduced Fraud Impact

Early identification can help organizations:

- Block malicious messages
- Warn users
- Investigate compromised accounts
- Identify suspicious infrastructure
- Respond to fraud
- Preserve evidence

The exact reduction in financial loss would need to be measured experimentally; it should not be claimed automatically.

53. Expected Outcome 5 — Incident Response

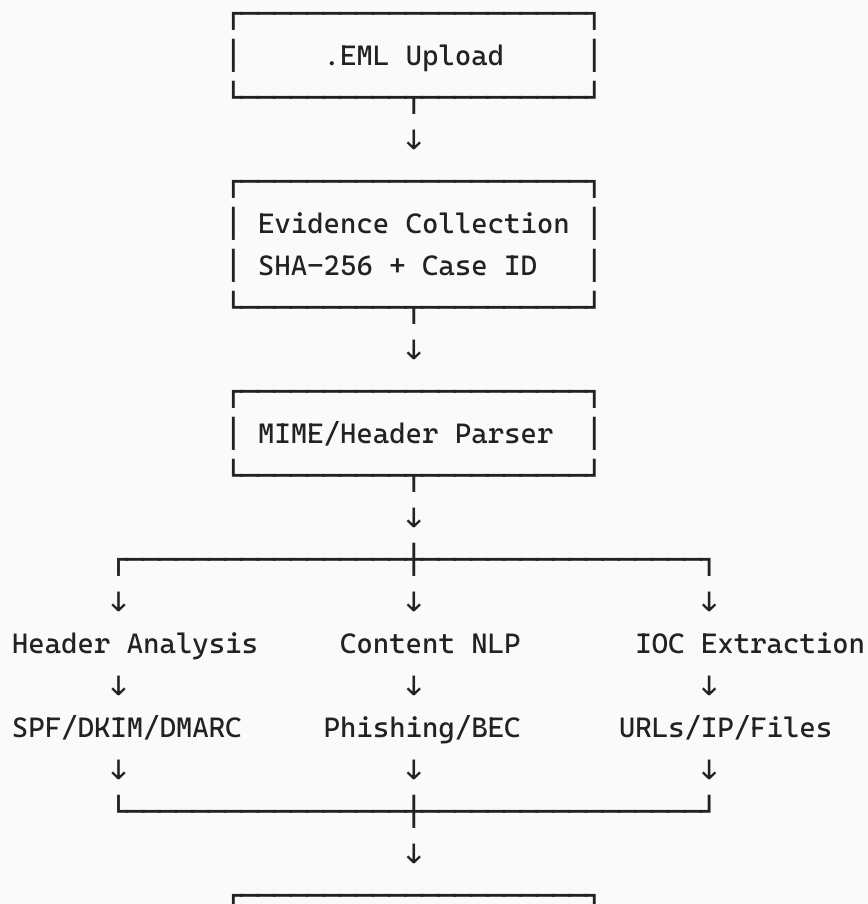
The platform can support a SOC or security team.

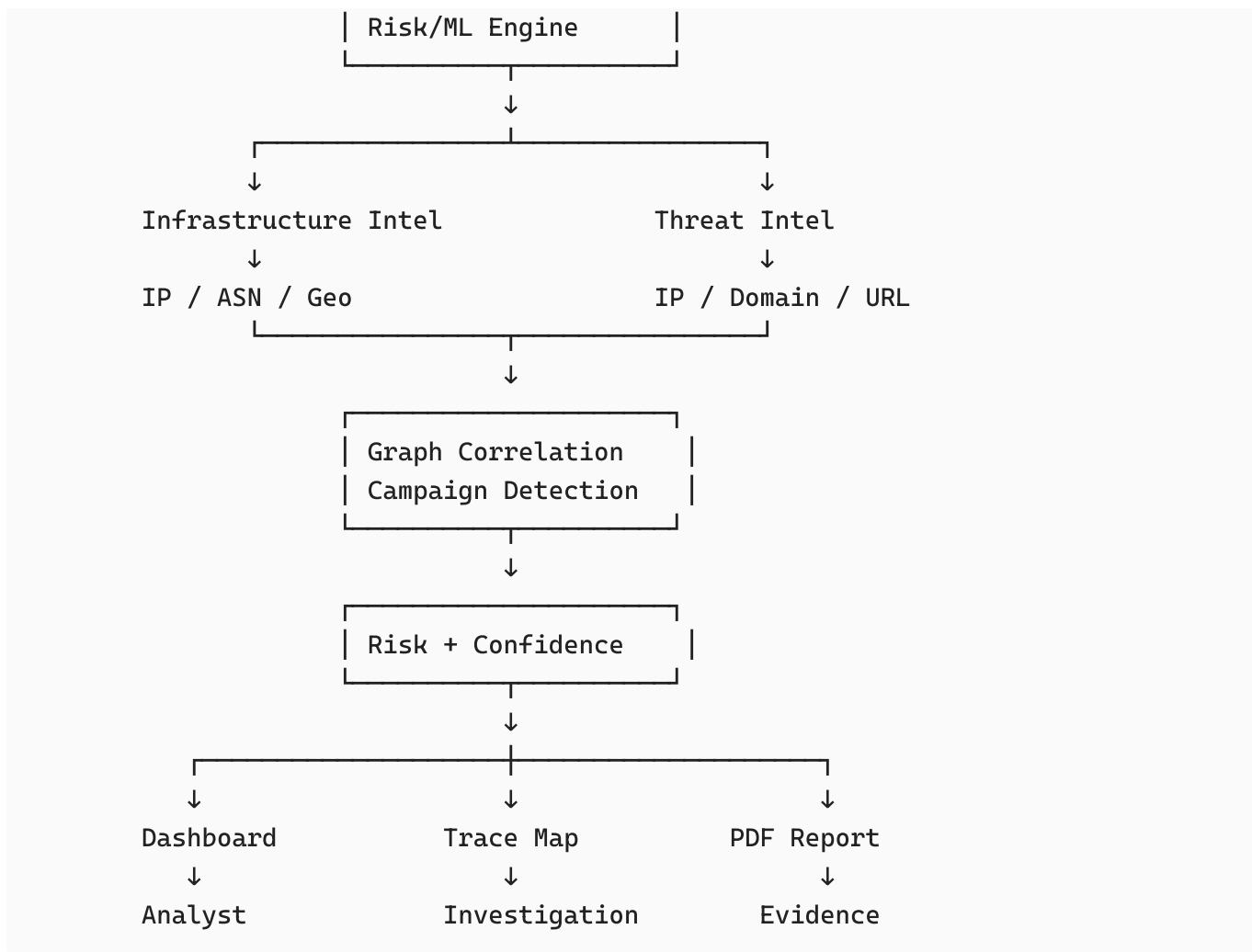
Example:

Alert
↓
SOC Analyst
↓
Investigate
↓
Correlate Indicators
↓
Create Case
↓
Preserve Evidence
↓
Generate Report
↓
Response / Escalation

54. Complete System Flow

This is the most important flow to understand for your project:





55. One Complete Example

Suppose a finance employee receives:

From:
CEO <ceo@company-secure.com>

Subject:
URGENT – Transfer ₹10,00,000

Body:
Please transfer the amount to the new vendor
account immediately.

Step 1 — Upload

invoice.eml

Step 2 — Hash

```
SHA-256 = XXXXXXXXX
```

Step 3 — Header extraction

System finds:

```
From  
Reply-To  
Received  
Message-ID  
SPF  
DKIM  
DMARC
```

Step 4 — Domain analysis

```
company-secure.com
```

is found to be visually similar to the legitimate organization domain.

Step 5 — NLP

System detects:

```
Urgency = HIGH  
Financial request = HIGH  
Executive impersonation = POSSIBLE
```

Step 6 — URL analysis

A payment-related URL is extracted.

```
URL → suspicious-domain.example
```

Step 7 — Authentication

```
SPF = FAIL  
DKIM = FAIL  
DMARC = FAIL
```

Step 8 — IP analysis

The earliest reliable visible infrastructure is:

```
IP → ASN → Hosting Provider → Approximate Geo
```

Step 9 — Threat Intelligence

The IP/domain has previous suspicious associations.

Step 10 — Graph

```
graph TD
    Email --- Domain
    Domain --- IP
    IP --- ASN
    Email --- URL
    Email --- Campaign
```

Step 11 — Risk

Example:

```
Risk Score: 94/100
Classification: Suspected BEC / Phishing
```

Step 12 — Report

The investigator receives:

```
Case ID
Email hash
Authentication results
Header analysis
Relay path
URLs
Domains
IP information
Threat intelligence
Risk score
Confidence
Evidence timeline
```

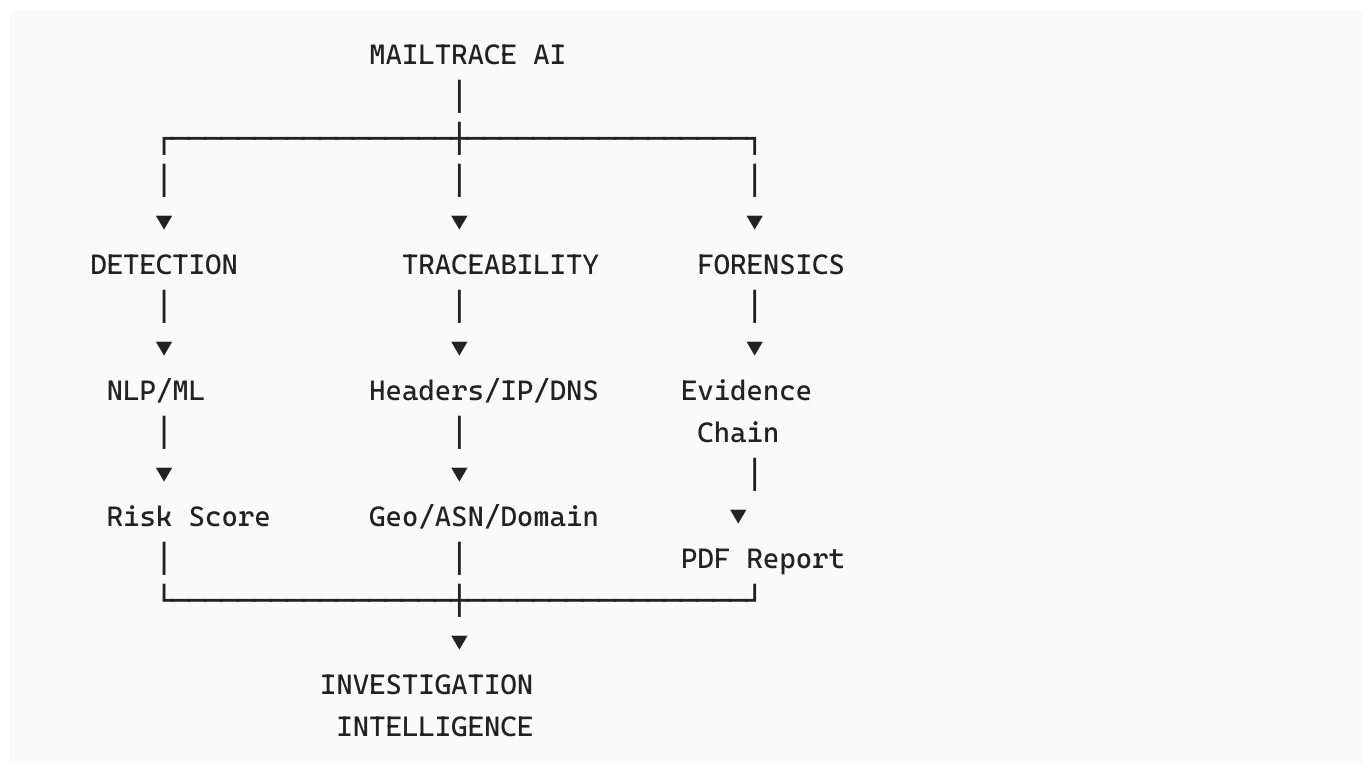
This is the **complete value proposition** of your project.

56. The Core Idea in One Sentence

Your project is essentially:

Detect the malicious email → understand why it is suspicious → reconstruct its technical path → enrich the infrastructure with intelligence → correlate it with related activity → preserve evidence → produce an investigation-ready report.

And the most important architectural distinction is:



One important think : we avoid promising that the platform can *"identify the attacker"* or *"reveal the exact sender location."* Email headers, IP geolocation, VPN/Tor, cloud hosting, compromised accounts, and spoofing make that technically unreliable in many cases. The defensible claim is **probable origin, infrastructure intelligence, correlation, and attribution support with confidence levels.**

Top 10 MVP Module Names

1. **Email Evidence Intake**
2. **Header Forensics Engine**
3. **Authentication Analyzer**
4. **Phishing Detection Engine**

5. **IOC Extraction Engine**
6. **Origin Trace Engine**
7. **IP & Geo Intelligence**
8. **Threat Intelligence Correlator**
9. **Campaign Graph Analyzer**
10. ****Forensic Report Generator**

#MailTrace AI — Advanced Tech Stack

MailTrace AI — Technology Stack

#	Layer	Technology / Algorithm	Purpose
1	Frontend	React + TypeScript	Analyst dashboard, case management, risk visualization, trace map
2	API Backend	FastAPI	REST APIs, email analysis services, and AI inference endpoints
3	Core Language	Python	Email processing, ML, NLP, threat analysis, and automation
4	Database	PostgreSQL	Cases, users, findings, IOCs, risk scores, and investigation history
5	Evidence Storage	MinIO	.eml files, attachments, forensic evidence, and generated reports
6	Classical ML	XGBoost + LightGBM	Phishing/BEC classification using structured email and header features
7	Anomaly Detection	Isolation Forest	Detect unusual email patterns and previously unseen anomalies
8	Deep Anomaly Detection	VAE / Autoencoder	Learn normal email representations and identify anomalous behavior
9	NLP / Deep Learning	Transformers / BERT	Semantic analysis, phishing, BEC, and social-engineering detection
10	Sequence Deep Learning	CNN + BiLSTM	Learn local text patterns and sequential/contextual email patterns
11	Graph AI	GAT (Graph Attention Network)	Analyze relationships between senders, domains, URLs, IPs, and campaigns
12	NLP Processing	spaCy	Entity extraction, text preprocessing, and linguistic analysis
13	Infrastructure Intelligence	DNS + WHOIS APIs	Domain information, DNS records, registration, and infrastructure analysis

#	Layer	Technology / Algorithm	Purpose
14	Threat Intelligence	Threat Intelligence APIs	IOC reputation and malicious IP/domain/URL intelligence
15	Deployment	Docker	Containerized frontend, backend, AI models, and supporting services

Technology Stack — Security Note

Deployment and web-application security practices (authentication, HTTPS, CSRF/XSS protection, rate limiting, secrets management, and secure Docker configuration) are described in detail in **Section 48C — Web Application Security Controls**.

This explicit linkage makes clear that the listed technologies are not only functional components but are also operated under documented security controls appropriate for a forensic intelligence platform.

